

Vulnerability fixes

With so many different ways of fixing a software vulnerability, the definition, 'vulnerability fixes' is now used as an umbrella term instead of 'updates' or 'patches'.

It's a recognised cyber security principle that if you have a vulnerability on a software system, it needs to be fixed before a cyber criminal can exploit it. The vendors or the manufacturers of the software and the operating systems repair the vulnerability by releasing patches and updates, but they're also doing it in other ways. These include registry fixes, configuration changes, or running scripts provided by the vendor.

Transforming definitions

The 2025 changes to Cyber Essentials Requirement for IT Infrastructure V 3.2 include a few adjustments to some definitions, made necessary by innovations to technology. Under the control, security update management, the description that used to be 'patches and updates' will be changed to 'vulnerability fixes' as an umbrella term for all the different methods.

Vulnerability fixes include patches, updates, registry fixes, configuration changes, scripts or any other mechanism approved by the vendor to fix a known vulnerability.

When should vulnerability fixes be applied?

All software on in scope devices must be:

- Licensed and supported
- Removed from devices when it becomes un-supported or removed from scope by using a defined 'sub-set' that prevents all traffic to/from the internet.
- Have automatic updates enabled where possible
- Updated, including applying any manual configuration changes required to make the update effective, within 14 days of an update being released, where:

The update fixes vulnerabilities described by the vendor as 'critical' or 'high risk'

The update addresses vulnerabilities with a *CVSS v3 score of 7 or above

There are no details of the level of vulnerabilities the update fixes provide by the vendor

***The Common Vulnerability Scoring System (CVSS)** provides a numerical representation of the severity of software vulnerabilities, so that IT security teams can compare and prioritise their management.

Why must all high and critical updates must be applied within 14 days?

In 2021, a vulnerability in the Microsoft Exchange System came out very publicly and was reported by numerous news outlets. That attack went from being a complex state actor attack to a **commodity** attack within seven days. It was commoditised into a ransomware attack only 12 hours later. This proves that a high complexity attack can be ***commoditised** in hours and for this reason, all high and critical updates, need to be applied within 14 days, both for Cyber Essentials and Cyber Essentials Plus.

What is a commodity attack?

Commodity is a term used to describe common, low skill, low sophistication cyber attacks that rely on tools which are widely available on the internet, eg a phishing attack.

When talking about cyber attacks, the term '**commoditised**' refers to the process by which certain types of cyber attacks become standardised, widely available, and relatively easy to execute, often due to the availability of tools and services that can be purchased or accessed with minimal effort or expertise. This commoditisation can lower the barrier to entry for cybercriminals, making it easier for a larger number of individuals or groups to carry out attacks.

